

08 - Email & Phishing Analysis

1: Email Headers Basics

Email Header Structure

Headers are read BOTTOM to TOP (oldest → newest)

To: victim@company.com	← Recipient
From: ceo@company.com	← Claimed sender (can be spoofed!)
Subject: Urgent Wire Transfer	
Date: Mon, 15 Mar 2024 10:23:45	
Message-ID: <abc123@mail.com>	
X-Originating-IP: 45.142.212.61	← Real sender IP
Received: from mail.evilm.com	← Mail servers path
Authentication-Results: spf=fail	← SPF/DKIM/DMARC results

Key Headers to Analyze

Header	What It Shows	Why Important
From	Claimed sender	Can be spoofed
Reply-To	Where replies go	Often different in phishing
Return-Path	Bounce address	Helps identify real sending domain
Received	Mail server path	Used to trace email origin
X-Originating-IP	Sender's real IP	Helps identify attacker infrastructure
Authentication-Results	SPF/DKIM/DMARC status	Verifies sender legitimacy

2: SPF / DKIM / DMARC

The Email Authentication Trinity

SPF → Who can SEND for this domain?
DKIM → Is the email AUTHENTIC (not modified)?
DMARC → What to DO if SPF/DKIM fails?

SPF (Sender Policy Framework)

PURPOSE: Verify sender IP is authorized

HOW IT WORKS:

1. Email claims to be from: company.com
2. Receiver checks: company.com's SPF record
3. SPF record says: "Only these IPs can send for us"
4. If sender IP matches → PASS 
5. If sender IP doesn't match → FAIL 

SPF Results:

SPF (Sender Policy Framework) Results Explained

Result	Meaning	Action
spf=pass	Authorized sender 	Likely legitimate
spf=fail	Unauthorized sender 	Likely spoofed
spf=softfail	Probably unauthorized	Suspicious
spf=neutral	No explicit allow/deny	Cannot verify
spf=none	No SPF record found	Cannot verify

DKIM (DomainKeys Identified Mail)

PURPOSE: Verify email wasn't modified in transit

HOW IT WORKS:

1. Sending server signs email with private key
2. Signature added to header
3. Receiver gets public key from DNS
4. Receiver verifies signature
5. If signature valid → PASS 
6. If signature invalid → FAIL 

DKIM Results:

Result	Meaning
dkim=pass	Email authentic, not modified 
dkim=fail	Email modified or forged 
dkim=none	No DKIM signature present

DMARC (Domain-based Message Authentication)

PURPOSE: Tell receivers what to do if SPF/DKIM fail

HOW IT WORKS:

1. Domain publishes DMARC policy
2. Policy says: "If SPF/DKIM fail, do X"
3. X can be: none, quarantine, or reject

DMARC Policies:

Policy	Action
p=none	Monitor only, no action
p=quarantine	Send to spam folder
p=reject	Block the email completely

DMARC Results:

Result Meaning

dmARC=pass Email passed authentication 

dmARC=fail Email failed authentication 

3: Extract Sender IP & Identify Spoofing

Finding Real Sender IP

Method 1: X-Originating-IP Header

```
X-Originating-IP: [45.142.212.61]
```

→ This is the sender's actual IP

→ Look this up in threat intel (AbuseIPDB, VirusTotal)

Method 2: Received Headers (Read Bottom to Top)

```
Received: from mail.company.com (10.0.0.5) by mx.google.com
```

```
Received: from unknown (45.142.212.61) by mail.company.com ← REAL ORIGIN
```

```
Received: from localhost (127.0.0.1) by unknown ← OLDEST (START)
```

Read bottom → top

First external IP = Real sender IP

Example:

Email claims: From: ceo@company.com

HEADERS (bottom to top):

- 3. Received: by mx.google.com (recipient's server)
- 4. Received: from mail-sender.com [45.142.212.61] ← REAL SENDER
- 5. Received: from localhost

ANALYSIS:

- Claimed domain: company.com
- Real sender: mail-sender.com (45.142.212.61)
- MISMATCH → SPOOFED EMAIL 🚨

Common Spoofing Techniques

Technique	Real Domain	Spoofed Domain Example
Typosquatting	microsoft.com	micros0ft.com, mircosoft.com
Homograph	apple.com	apple.com (Cyrillic 'a')
Subdomain	company.com	company.com.evil.com
Added Word	paypal.com	paypal-secure.com
TLD Swap	amazon.com	amazon.org, amazon.co

4: Analyzing Attachments & URLs

Attachment Analysis

Step 1: Get File Hash (Without Opening!)

```
# Windows PowerShell
Get-FileHash -Algorithm SHA256 .\suspicious_file.exe

# Linux
sha256sum suspicious_file.exe
```

Step 2: Check Hash on VirusTotal

URL: <https://www.virustotal.com>

STEPS:

- 1. Go to Search tab
- 2. Paste file hash

3. Check detection ratio

RESULTS:

0/70 → Likely clean (or brand new malware)

5/70 → Suspicious, investigate further

40/70 → Confirmed malicious 🚨

Step 3: Sandbox Detonation

Safe environments to execute suspicious files:

Online Malware Analysis Tools

Tool	URL	Best For
Any.Run	https://any.run	Interactive analysis
Hybrid Analysis	https://hybrid-analysis.com	Detailed reports
Joe Sandbox	https://joesandbox.com	Deep analysis
VirusTotal	https://virustotal.com	Quick reputation scan

WHAT SANDBOXES SHOW:

- Network connections (C2 servers)
- File modifications
- Registry changes
- Process creation
- Screenshots of behavior

URL Analysis

NEVER Click Suspicious Links Directly!

Safe URL Analysis Tools:

Tool	URL	Purpose
URLScan.io	https://urlscan.io	Screenshot, IP, linked resources
VirusTotal	https://virustotal.com	Detection ratio & reputation
CheckPhish	https://checkphish.ai	Phishing detection
URL2PNG	https://url2png.com	Safe webpage screenshot

URLScan.io Analysis:

SUBMIT URL → GET:

- Screenshot (see page without visiting)
- Final destination (after redirects)
- IP address
- Technologies detected
- Linked domains
- Malicious indicators

Suspicious URL Indicators:

Indicator	Example	Risk
IP instead of domain	http://45.142.212.61/login	High 🚨
Long random string	http://evil.com/a3f2x9y8z	High 🚨
URL shortener	bit.ly/xyz123	Medium
Misspelled brand	paypa1-secure.com	High 🚨
Suspicious TLD	company.tk, login.ml	High 🚨
@ symbol in URL	http://google.com@evil.com	High 🚨

5: Spam vs Malicious

Key Differences

Aspect	Spam	Malicious Phishing
Intent	Advertising, annoyance	Steal credentials, deploy malware
Attachments	Usually none or PDFs	Executables, Office files with macros
Links	Product pages, unsubscribe links	Fake login pages, malware downloads
Urgency	"Limited offer!"	"Account suspended!" "Act now!"
Spoofing	Usually from real sender	Spoofed trusted brands
SPF/DKIM	Often pass	Often fail (but may pass in advanced attacks)
Response	Block sender, ignore	Investigate, block IOCs, alert users

Analysis Decision Tree

START: Suspicious Email Received

- |— Check SPF/DKIM/DMARC
 - |— FAIL → Likely Spoofed → MALICIOUS 🚨
 - |— PASS → Continue analysis
- |— Has Attachment?
 - |— .exe/.js/.vbs/.scr → MALICIOUS 🚨
 - |— .docm/.xlsm (macro) → MALICIOUS 🚨
 - |— .pdf/.docx → Check hash in VT
- |— Has Link?
 - |— Fake login page → MALICIOUS 🚨
 - |— URL shortener → Expand & analyze
 - |— Product page → Likely SPAM
- |— Requests Credentials/Payment?
 - |— YES → MALICIOUS 🚨
 - |— NO → Continue
- |— Verdict:
 - |— MALICIOUS → Block IOCs, alert users, report
 - |— SPAM → Block sender, no urgent action